Ochrona danych w systemach informatycznych

Laboratorium 5
Bezpieczeństwo serwera WWW

Jakub Ciszewski

Semestr 2026Z

Plan i zasady

90 minut (2 × 45). Trzy zadania po 1 pkt.

Katalogi: 20 min. Hasła: 20 min. CGI: 25 min.
15 minut na raport i oddanie.

ISOD, dokumentacja i własne notatki są dozwolone.
Podczas zajęć wyłącz czaty i podpowiedzi LLM.

Własna konfiguracja i kod na GitHubie.
Jeden raport tekstowy, dowolna nazwa pliku.

Warstwy kontroli dostępu

Warstwa	Co kontroluje
Konfiguracja Apache	Dostęp do zasobu przez HTTP
Logowanie Basic	Tożsamość użytkownika HTTP
Uprawnienia plików	Odczyt przez proces w systemie

Każda warstwa odpowiada za inną decyzję o dostępie.

Kody odpowiedzi w ćwiczeniu

Kod	Znaczenie	Przykład
200	OK	Odpowiedź z zasobem
401	Brak uwierzytelnienia	Brak lub błędne hasło
403	Odmowa dostępu	Zakaz w konfiguracji
500	Błąd serwera	Problem z wykonaniem CGI

Kod odpowiedzi i treść sprawdzamy osobno.

Zadanie 1: dostęp do katalogów

Sprawdź cztery adresy z poleceń B.
Zapisz kody przed zmianą konfiguracji.

W materialy/ wyłącz listowanie.
Plik notatka.txt ma nadal być dostępny.

W wewnetrzne/ zablokuj cały dostęp HTTP,
także do pliku plan.txt.

Sprawdź składnię, zrestartuj i ponów żądania.
Wskaż w logu jedną odmowę dostępu.

Listowanie a odczyt pliku

Reguła	Lista katalogu	Znany plik
Options Indexes	Dostępna	Dostępny
Options -Indexes	Wyłączona	Dostępny
Require all denied	Zablokowana	Zablokowany

Porównanie dotyczy katalogu bez pliku indeksowego.

Logowanie HTTP Basic

htpasswd przechowuje skrót hasła.
Opcja -B wybiera bcrypt.

Plik bazy leży poza DocumentRoot.
Serwer musi mieć prawo jego odczytu.

Basic koduje dane logowania w Base64.
Poufność transmisji zapewnia HTTPS.

```
Konto HTTP: student.
Użytkownik procesu WWW: daemon.
```

Testy dostępu do panelu

Żądanie	Dane logowania	Kod
/panel/raport.txt	Brak	401
/panel/raport.txt	Błędne hasło	401
/panel/raport.txt	Poprawne hasło	200
/	Brak	200

Przy 401 sprawdź nagłówek WWW-Authenticate.

Zadanie 2: dostęp na hasło

Utwórz użytkownika student przez htpasswd.
Hasło wpisz interaktywnie.

Zabezpiecz katalog panel/ mechanizmem Basic.
Baza: /auth/uzytkownicy.

Sprawdź brak hasła, błędne i poprawne hasło.
Publiczna strona / ma pozostać dostępna.

W raporcie: kody, nagłówek i wyjaśnienie.
Baza haseł pozostaje lokalna.

CGI i prawa systemu plików

Program zwraca Content-Type, pustą linię
i treść odpowiedzi.

Efektywny UID/GID określa tożsamość procesu.
Prawa pliku sprawdza system operacyjny.

W obrazie oba pliki należą do root:daemon.
ogolny.txt ma 640, poufny.txt ma 600.

Logowanie Basic sprawdza użytkownika HTTP.
Nie zmienia UID/GID uruchomionego CGI.

Zadanie 3: uprawnienia CGI

Napisz własne cgi-bin/uprawnienia.cgi.
Python 3 albo sh, plik zapisany z LF.

Wypisz UID/GID i spróbuj odczytać oba pliki.
Obsłuż odmowę odczytu w programie.

Przebuduj obraz. Porównaj odpowiedź CGI
z właścicielami i prawami plików.

Dodaj Basic do katalogu CGI.
Porównaj kody HTTP, UID/GID i odczyty.

Oddanie do końca zajęć

Jeden plik tekstowy: np. TXT, MD lub PDF z tekstem.
Raport: 1 strona. Pełne dowody w repozytorium.

Imię, nazwisko i indeks.
Link do GitHuba i identyfikator commitu.

Wyniki i krótkie odpowiedzi z trzech zadań.
Raport należy oddać do końca zajęć.

W repozytorium: konfiguracja, CGI i README.
Nie dodawaj bazy haseł.

Pytania przy odbiorze

Czym różni się brak listy od zakazu dostępu?

Czy bcrypt chroni hasło przesyłane przez Basic?

Dlaczego konto HTTP nie zmienia UID procesu?

Za zadanie: 0,50 pkt konfiguracja lub kod,
0,25 wyniki, 0,25 wyjaśnienie.

Materiały do przygotowania

ISOD: Laboratorium 5.
Bezpieczeństwo serwera usług WWW.

Dokumentacja Apache 2.4:
kontrola dostępu, Basic, htpasswd i CGI.

Przed zajęciami: Docker Compose i GitHub.
Zbuduj i sprawdź środowisko według START.md.

Zakres: A-przygotowanie.txt.
Wymagania zadań i raportu: B-polecenia.